A05 - Injection

- **Problem:** Untrusted user input is interpreted as executable commands or queries
- **Impact:** Unauthorized data access, modification, deletion, or arbitrary code execution

Common vulnerabilities:

- **SQL/NoSQL injection:** Manipulating database queries
- **Command injection:** Executing arbitrary OS commands
- **Other injections:** LDAP, ORM, or expression language injection
- **Unsafe input handling:** Concatenating untrusted data into queries or commands
- **Insufficient validation:** Failing to validate or sanitize user input

Preventing Injection

✓ **Key principle:** Treat all user input as data, never as executable code

- **Validate input:** Apply strict server-side validation
- **Separate data from commands:** Never concatenate untrusted input into executable queries
- **Use parameterized queries:** Prefer prepared statements and safe APIs
- **Escape when necessary:** Use interpreter-specific escaping when parameterization is impossible